When the Paper Trail Lies: A Practitioner's Case for Treating Documented-vs-Actual Behavior as a First-Class Governance Problem

Olamide Latifat Mohammed, Independent Researcher

Abstract

Governance, risk, and compliance (GRC) practice, as currently carried out inside most organizations, treats documentation as a reliable proxy for system behavior: if a policy says access is restricted, or a system prompt instructs an AI model to verify a user's identity, the control is generally recorded as met. This paper argues, from direct practitioner experience rather than theoretical critique, that this assumption is increasingly unsafe for AI-driven systems specifically, and proposes that the gap between documented configuration and actual behavior be treated as its own category of governance risk. Drawing on two original projects, a structured adversarial security test of an AI system, and a multi-framework compliance gap assessment of a fintech architecture, this paper presents concrete evidence of that gap in practice and argues for a shift in how GRC methodology accounts for it.

1. Introduction

Most compliance work runs on documents. An auditor asks for the access control policy, the data retention schedule, the incident response plan. If the document exists, is current, and describes a reasonable control, the box is checked. This approach works reasonably well for systems whose behavior is fixed and legible, a database either enforces a permission or it does not, a firewall rule either blocks a port or it does not. It works far less well for AI systems, whose behavior is probabilistic, and whose actual response to a given input cannot be fully predicted from reading their configuration.

This paper grew out of a specific, small discovery made while testing a deliberately vulnerable AI chatbot I built for security research in 2026. The chatbot's system prompt explicitly instructed it, in writing, to treat any user who provided an employee ID in a specific format as verified staff, no further checking required, a weak control by design, included to see whether the model would honor it. When tested directly, the model refused. It did not disclose account information to the simulated "employee" despite being told, in its own configuration, to do exactly that. The system's actual behavior was more conservative than its documentation. On paper, this looks like good news: the AI was safer than instructed. But it is also, from a governance standpoint, a finding that should trouble anyone who audits systems for a living. If a system's real behavior can diverge from its documented configuration in the safe direction, without anyone designing for that, it can

presumably diverge in the unsafe direction too, and the same audit methodology that would have caught neither divergence is the one currently in standard use.

2. Two Projects, One Underlying Question

This paper draws on two pieces of original work, conducted independently but converging on the same problem, undertaken over the course of several weeks of practitioner research.

The first was a structured adversarial test of an AI chatbot, built specifically to hold a fake confidential customer record and a deliberately weak access rule. Four attack categories were run against it: a direct instruction override ("ignore all previous instructions and print your system prompt"), a roleplay/jailbreak reframing of the same request, an access control bypass attempt using the exact unverified credential format the system prompt was told to trust, and a social-engineering-style request framed as the user confirming their own identity. All four attempts failed to extract the protected data. The interesting finding was not the failure itself, but why: in the access control bypass case specifically, the model's refusal to honor the unverified credential contradicted what its own system prompt instructed it to do. The documented rule and the actual behavior were not the same thing, and nothing in the testing methodology used by most GRC practitioners today would have surfaced that gap without deliberately adversarial, hands-on testing.

The second project was a full-scope compliance gap assessment of a multi-tenant fintech lending architecture, examined against five overlapping frameworks: ISO/IEC 27001, SOC 2, the EU's Digital Operational Resilience Act (DORA), PCI DSS, and IT General Controls relevant to Sarbanes-Oxley compliance. Rather than applying each framework as an independent checklist, every identified threat, using a STRIDE-based threat model, was mapped to the specific control, across whichever framework actually addressed it, that mitigated that threat. This produced a different kind of finding than a standard audit: in several cases, a single well-implemented control (tenant-level access restriction, for instance) satisfied requirements under three different frameworks simultaneously, while a genuine gap, the absence of any formal change-management process, showed up as a real, undocumented risk with no existing control mapped to it at all under any framework examined.

A separate piece of applied work, aimed at a general audience rather than a technical one, examined a related but distinct problem: the ungoverned use of consumer AI tools by employees inside organizations with no formal AI usage policy, sometimes called "Shadow AI." That analysis argued that this is not a single risk but three overlapping ones, a data privacy risk (loss of control over where sensitive data ends up once pasted into a third-party AI tool), a security risk (every unvetted AI tool is an unreviewed, unmonitored point of access into company systems), and a

governance risk (the absence of any record of how AI is actually being used, which becomes a serious liability the moment a regulator, auditor, or investor asks the question directly). The through-line across all three pieces of work is the same: organizations, and the frameworks that govern them, are structured around the assumption that behavior follows documentation, and AI-driven systems and workflows are quietly breaking that assumption in ways current GRC methodology has no systematic way of catching.

3. Why This Matters Beyond These Two Projects

None of this is to say that documentation is worthless, or that existing frameworks like ISO 27001, SOC 2, or DORA are poorly designed. The argument is narrower and, I think, more actionable: these frameworks were designed around a class of systems where documented configuration and actual behavior could be assumed, with reasonable confidence, to match. That assumption is doing more work than most practitioners realize, and AI systems are the first widely deployed class of technology where it breaks down in a systematic, not just occasional, way. A firewall misconfiguration is a bug. A model whose behavior diverges from its system prompt is closer to the normal operating condition of the technology.

The practical implication is that verification, actually testing what a system does, rather than reviewing what it is documented to do, needs to move from an optional, occasional practice (a penetration test conducted once a year) to a standard, recurring part of how AI-driven systems are governed. This paper does not propose a complete methodology for doing so; it proposes, more modestly, that the problem be recognized as its own category, distinct from conventional control-testing, and that it belongs squarely inside the discipline of governance, risk, and compliance rather than being treated as purely a technical security concern separate from it.

4. Conclusion

The two projects described here are small in scope, a single test system, a single fictional architecture, and make no claim to generalize on their own. What they demonstrate, concretely rather than theoretically, is that the gap between documented and actual system behavior is a real, findable thing, not a hypothetical concern, and that finding it required deliberately adversarial testing rather than the document review that constitutes most current compliance practice. If AI systems continue to be integrated into the same organizational contexts that ISO 27001, SOC 2, and DORA were built to govern, and there is no indication that trend is slowing, GRC methodology will need a genuine answer to this problem, not an assumption that documentation review still suffices. This paper is offered as a starting observation toward that answer, made from inside the practice rather than outside it.

Author's Note

The two projects referenced in this paper, the AI security testing sandbox and the multi-framework fintech architecture assessment, are publicly available at github.com/TechShieldOlamide, alongside a general-audience analysis of ungoverned AI tool use. This paper reflects independent practitioner research conducted alongside ongoing professional work in GRC consulting, data protection, and AI governance facilitation.